

Admin surfaces

Wallflower.tv — every operator page and endpoint, what it shows, and what it can do

Internal. Not published to the site — this file lives in `docs/`, which is outside the served asset directory (`./dist`). Do not move it into `public/`.

Three consoles, one password, no accounts. Everything here is gated on a single `ADMIN_PASSWORD` secret presented as `Authorization: Bearer <password>`. There is no admin user table, no roles and no audit trail of who acted — a deliberate consequence of a system built to hold as little identity as possible, and a real limitation worth knowing before more than one person holds the password.

1. The three consoles

URL	What it is	What you can do from it
wallflower.tv/reports	Abuse queue and kill switch	Read reports grouped by stream, view an attached frame, remove a frame or delete the reports, terminate a stream, allow a terminated name again, mark handled
wallflower.tv/audience	Viewing statistics	Sessions per stream, watching-now, average and total view time, per-stream session detail, date filters, CSV export
wallflower.tv/seeds-admin	Seeds console (<i>demo</i>)	Inspect vaults and the ledger, credit seeds, reset the demo

[/reports](http://wallflower.tv/reports) — the abuse queue

The operator console for the one enforcement action that exists. Reports are grouped by stream, because a stream is the unit you act on: ten reports about one broadcast is one decision, not ten. Rows carrying the severe category are tagged, and terminated streams are marked.

- **Nothing here acts on its own.** Reports do not accumulate into a kill. A threshold that fired by itself would be a harassment tool, because filing a report needs nothing but a share link and one hostile invitee can file repeatedly.
- **Frames.** Where a reporter attached a still, it renders inline; click to enlarge. Frames are fetched over an authenticated request into an object URL rather than a public URL, and expire after 30 days while the report row survives.
- **Two ways to remove something, and they are different acts.** *Remove this frame* nulls the column and keeps the complaint — the same thing retention does on its 30-day clock, available on demand, and the one you want most of the time. *Delete these reports* removes the rows, which also loses the record that anyone ever complained; that record is what you want back when a pattern shows up later, so it is offered second.
- **Terminating** stops new connections and rotates the stream's salt so anyone re-deriving gets a different key. Anyone already connected stays until their relay token expires — we cannot reach into a QUIC session we are not part of.
- **"Allow the name again"** frees the stream id. It does *not* undo the rotated salt: links from before the kill still decrypt nothing.

/audience — viewing statistics

One row per stream, expandable to the individual sessions. Two things about the numbers that are easy to misread:

- **A row is a viewing session, not a person.** One browser tab and how long it watched. Nothing is stable across sessions, so two rows can never be shown to be the same human — on one stream or across streams. A viewer who reloads counts twice. That is the cost of not keeping an identifier that could be demanded from us later.
- **"Unmeasured" is a separate column, not a zero.** Sessions recorded before heartbeats existed are real but of unknown length, and are excluded from every average rather than counted as zero-second views — which would drag each stream's average toward nothing on the strength of rows nobody measured. No new session can be unmeasured; that count only falls.

/seeds-admin — the seeds console

Demo-stage. Vaults, the ledger, and manual crediting. Standalone for the same reason as `/reports`: it holds the admin password and has no business in the document that handles content keys derived from share links.

2. One password, and what follows from it

All three consoles share `ADMIN_PASSWORD`, set with `wrangler secret put ADMIN_PASSWORD`. If it is unset, admin fails closed with a 503 rather than open. There is no per-person credential, so access cannot be withdrawn from one holder without rotating it for everyone, and no record exists of which holder took which action.

Each console stores the password in `sessionStorage`, not `localStorage` — an operator credential should not outlive the tab. (The broadcaster's publish key is deliberately remembered per device; this deliberately is not.)

All three are standalone documents that share no script with the app bundle. That separation is load-bearing rather than tidiness: the app document holds a content key derived from a share link, and the admin password has no business in the same page.

3. Pages that look adjacent but are not admin

Listed so nobody spends time looking for a password prompt that is not there.

URL	What it is
/request	Public. Proof-of-work gated request for a publish code. No credential needed to load it — that is the point.
/trust	Public. The plain-language privacy and moderation page, including what we can and cannot do.
/partner	Public. How to run a partner fleet.
/url-parameters	Public. Viewer URL parameters and transport overrides.

4. Dead routes

These return `200` and render the app shell, which no longer has a view for them. They are vestigial and show nothing:

- `/stats`, `/<stream>/stats`, `/cleardata` — removed from the client because they existed to show who was broadcasting and watching, which is exactly the identity this app no longer holds. The Worker still routes them to `index.html`.

If you want them gone properly, the fix is in the SPA route test in `src/worker/index.ts` (`isStatsPage`, `isStreamStatsPage`, `isClearDataPage`).

5. The full API surface

Everything below sits behind the bearer check, except `/api/admin/verify`, which is the password check itself and returns `{valid:false}` rather than data.

Method	Path	Purpose
GET	<code>/api/admin/verify</code>	Check a password without fetching anything
GET	<code>/api/admin/reports</code>	The queue. Returns <code>has_frame</code> , never frame bytes
GET	<code>/api/admin/reports/frame?id=</code>	One reported still, as <code>image/jpeg</code>
POST	<code>/api/admin/reports/ack</code>	Mark handled, by <code>stream_id</code> or <code>ids[]</code>
POST	<code>/api/admin/reports/drop-frame</code>	Forget the picture, keep the complaint. <code>{id}</code> or <code>{stream_id}</code>
POST	<code>/api/admin/reports/delete</code>	Remove the reports themselves, frames included
POST	<code>/api/admin/kill</code>	Terminate one stream and rotate its salt
POST	<code>/api/admin/unkill</code>	Free the stream id again (salt stays rotated)
POST	<code>/api/admin/kill-all</code>	Rotate the <i>global</i> salt — every stream re-keys at once
GET	<code>/api/admin/killed</code>	What has been terminated, and the recorded reason
GET	<code>/api/admin/stats/streams</code>	Audience overview, one row per stream
GET	<code>/api/admin/stats/stream/<id></code>	Every session on one stream, newest first
POST	<code>/api/admin/mint-code</code>	Issue a publish code directly, skipping the proof of work
POST	<code>/api/admin/revoke-batch</code>	Cut off an entire issuance cohort before its codes expire
POST	<code>/api/admin/revoke-code</code>	Cut off one code without learning whose it is
GET	<code>/api/admin/seeds</code>	Vaults and ledger (demo)
POST	<code>/api/admin/seeds/credit</code>	Credit a vault (demo)
POST	<code>/api/admin/seeds/reset</code>	Reset the demo
DELETE	<code>/api/admin/broadcasts</code>	Clear broadcast data
DELETE	<code>/api/admin/viewers</code>	Clear viewer data

Method	Path	Purpose
GET / POST / DELETE	<code>/api/admin/broadcasters</code>	OAuth-era allow list. No console calls it — see §6

kill-all has no button, and that is deliberate. It rotates the global salt, so every live broadcast on the service re-keys at once and every viewer drops. It exists for a compromise, not for moderation. Reaching it requires a deliberate `curl`.

6. Known rough edges

- **D1 Time Travel outlives a delete.** Cloudflare keeps a rolling ~30-day restore history, and a deleted row stays recoverable from it by anyone with account access. There is no API to scrub one row from that history; it ages out. "Deleted from D1" and "unrecoverable" are not the same sentence — both delete confirmations in `/reports` say so, because an operator acting on someone's behalf needs to know which of the two they just did.
- **No audit trail on deletion either.** The two controls above are destructive and nothing records which holder of the password used them. Same root cause as the entry below.
- **`/audience` is not a declared route.** Unlike `/reports`, `/trust`, `/request` and `/seeds-admin`, it is absent from `STANDALONE_PAGES` in the Worker and resolves only because Cloudflare's asset layer serves `public/audience.html` and rewrites the extension. It is not a security gap — `public/_headers` applies `frame-ancestors 'none'` to `/*`, so it still gets the anti-framing headers the Worker's `noFraming()` would add — but it is load-bearing on asset-layer behaviour rather than on anything declared. One line in the map fixes it.
- **`/api/admin/broadcasters` is vestigial.** It reads the `users` and `broadcaster_access` tables from the OAuth era. No console calls it, publishing is admitted by publish key and codes instead, and the tables hold one row each. Candidate for removal along with its tables.
- **No audit trail.** Nothing records which holder of the password terminated which stream. Acceptable at one operator; worth revisiting at two.

Last reviewed 26 August 2026. Verified against the deployed service: every URL in §1 and §3 returns 200, the two delete endpoints refuse an anonymous caller with a 401, and the endpoint list in §5 is enumerated from `handleAdminRoutes` in `src/worker/index.ts` and `src/worker/seeds.ts` rather than from memory.